Cybersecurity Incident Response Protocol

Policy ID: PRO-IR-008 | Version 1.0 | Classification: Internal

Policy Owner	CISO / Head of Security Operations	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This protocol defines the mandatory process for preparing for, detecting, reporting, triaging, containing, investigating, eradicating, recovering from, and learning from cybersecurity incidents. It is designed to reduce harm, preserve evidence, meet legal and regulatory obligations, restore services safely, and ensure executive accountability for material incidents.

2. Scope

This protocol applies to suspected or confirmed compromise of enterprise systems, cloud services, endpoints, networks, identities, applications, source code, suppliers, AI systems, personal data, cryptographic material, and customer environments where the enterprise has incident-response obligations. It applies 24x7 to employees, contractors, suppliers, and incident responders.

3. Governance, Accountability, and Roles

Incident Commander. Directs the incident, sets priorities, assigns workstreams, and maintains operational control.

Security Operations / DFIR. Performs triage, containment, evidence collection, investigation, eradication, and detection engineering.

IT/SRE/Engineering. Supports service containment, configuration changes, recovery, logging, and validation.

Legal / Privacy / DPO. Determines privilege strategy, regulatory obligations, contractual notifications, and personal-data breach requirements.

Communications / Executive Leadership. Approves external statements and major business decisions.

4. Policy Rules and Mandatory Guidelines

- Any person who suspects a cybersecurity incident MUST report it immediately through the approved security channel. Employees MUST NOT wait for proof before reporting.
- Incident severity MUST be assigned using the enterprise severity matrix based on confidentiality, integrity, availability, safety, legal, financial, customer, operational, and reputational impact. Severity may be raised as facts emerge.
- Responders MUST preserve evidence and timestamps. Uncoordinated deletion, reimaging, log clearing, or system reboot that could destroy evidence is prohibited unless necessary to prevent imminent harm and authorized by the Incident Commander.
- Containment has priority over convenience where active compromise threatens additional systems, identities, customers, or sensitive data. Security may isolate endpoints, disable accounts, revoke tokens, block traffic, suspend integrations, or take services offline.

- Compromised or potentially compromised credentials and keys MUST be rotated or revoked based on exposure analysis. Password reset alone is insufficient when session tokens, API keys, certificates, signing keys, or OAuth grants may also be compromised.
- Incident channels, documents, and evidence stores MUST be access-controlled. Sensitive investigation details MUST NOT be shared in broad chat rooms, public ticket queues, or unapproved collaboration tools.
- Only authorized Communications, Legal, Privacy, or executive personnel may make external statements about an incident. Responders MUST NOT speculate publicly or communicate with attackers outside approved procedures.
- Ransomware or extortion payment decisions are executive/legal decisions and MUST NOT be initiated by individual responders. Sanctions, legal, ethical, recovery, and law-enforcement considerations must be assessed.
- A personal-data breach assessment MUST begin promptly whenever unauthorized destruction, loss, alteration, disclosure of, or access to personal data is suspected. Regulatory timing begins based on legal awareness criteria, not when technical investigation is complete.
- Where GDPR Article 33 applies, the response process MUST support supervisory-authority notification within 72 hours after awareness unless the breach is unlikely to result in risk to individuals; delayed facts may be supplied in phases where legally permitted.
- Material supplier incidents MUST trigger third-party risk, legal, and business continuity coordination. The enterprise MUST obtain sufficient facts to assess downstream impact rather than rely only on vendor reassurance.
- All Severity 1 and Severity 2 incidents require a formal post-incident review. Significant near misses SHOULD also be reviewed when they reveal material control weaknesses.

5. Technical and Coding Constraints

- Security logs supporting critical systems MUST use synchronized time sources and be centrally retained to support investigation. Log sources SHOULD include identity, endpoint, cloud control plane, network, application, database, CI/CD, and security tooling according to system risk.
- Forensic collection MUST use methods appropriate to evidentiary needs, including hashing and chain-of-custody records when legal proceedings, insurance, or regulatory investigations are reasonably possible.
- Containment rules MUST be scripted or pre-authorized where feasible for high-confidence indicators, including malicious hashes/domains, stolen tokens, exposed cloud keys, and confirmed compromised endpoints.
- Restoration from backups MUST occur only after responders assess persistence, identity compromise, malware, and vulnerable entry points. Reintroducing a vulnerable or compromised image is not acceptable recovery.
- Recovered services MUST undergo validation for security controls, monitoring, access, data integrity, and critical business functions before incident closure.
- New detections and indicators derived from incidents MUST be added to monitoring where appropriate, with controls to avoid unnecessary collection of personal data.

6. Operational Control Requirements

- Incident records MUST maintain an event timeline, known facts, hypotheses, decisions, actions, evidence references, affected assets, communications, regulatory/legal determinations, and recovery status.
- Post-incident reviews MUST identify root and contributing causes, control gaps, lessons, assigned corrective actions, owners, due dates, and verification. The purpose is control improvement, while deliberate misconduct remains subject to separate HR/legal processes.
- Incident readiness MUST be exercised at least annually and more frequently for high-risk scenarios such as ransomware, cloud account takeover, source-code compromise, personal-data breach, or critical supplier outage.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable

regulation, and contractual requirements.

Minimum expected records:

- Incident tickets/case files
- Timelines
- Evidence and chain-of-custody records
- Containment actions
- Credential rotation records
- Regulatory/contract notification decisions
- Post-incident reviews
- Corrective action tracking

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Failure to report, intentional destruction of evidence, unauthorized disclosure of incident information, obstruction of investigation, or deliberate bypass of containment may result in disciplinary action up to termination and contractual or legal remedies. Security may take emergency protective action without normal change approval when necessary to contain an active incident, provided actions are documented and reviewed afterward.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

During an active incident, the Incident Commander may authorize temporary deviations from normal controls when necessary for containment or recovery, but the decision, risk, scope, and duration MUST be documented. Such emergency deviations expire when the incident need ends and do not create permanent exceptions.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports information security incident planning, assessment, response, evidence collection, learning, logging, backup, continuity, and improvement objectives.
NIST CSF 2.0	DE.AE adverse-event analysis; RS.MA incident management; RS.AN analysis; RS.CO reporting/communication; RS.MI mitigation; RC.RP recovery; RC.CO communication; RC.IM improvement.
GDPR	Articles 32, 33 and 34 are directly relevant to personal-data security and breach notification; Article 28 also affects processor notification obligations.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.